ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

KAVACH

Pre-execution action firewall for AI agents

ET-03 · Agentic AI Guardrail Validator



© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

Team Introduction

HACK-AI-THON 2026

[TEAM NAME]

COLLEGE

[College name | City]

TEAM MEMBERS

[Name 1] • [Name 2] • [Name 3]
[

SELECTED PROBLEM STATEMENT

ET-03 · Agentic AI Guardrail Validator (Lane 6, Emerging Technologies)

TECHNOLOGY TRACK

Qualcomm Cloud AI Playground (AI Inference Suite) · UNO Q optional



© 2026 Infosys Limited. All rights reserved.

Problem Statement

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

ACTUAL PROBLEM STATEMENT

"Check whether an AI agent's planned action is **safe, authorized, explainable and reversible**." MVP: agent action input → approve/block decision → guardrail explanation.

CURRENT GAP / PAIN POINT

Guardrails gate by **tool type or text**, or ask **another LLM**; none measure what this call will do. In AmPermBench, **36.8%** of state changes never reached Claude Code's classifier.
Manual approval (Tool Interrupt) does not scale, so users pick "always allow".

EVIDENCE / SCENARIO

EchoLeak CVE-2025-32711: zero-click exfiltration via one email.
GitHub MCP: a public issue made an agent leak private repos.
Replit: agent wiped a prod DB during a code freeze, then said rollback was impossible.
Llama-3.3-70B had the **highest attack success rate (6.49%)** in the UK AISI × Gray Swan red-team challenge.

WHO IS AFFECTED?

Enterprises letting agents act on DBs, email and payments: Infosys delivery teams, their BFSI/retail clients, security & audit reviewers, and the customers whose data agents touch.

WHY DOES IT MATTER?

Agents now act: one bad call deletes, leaks or pays. Gartner: >40% of agentic AI projects cancelled by 2027, citing inadequate risk controls. EU AI Act Art. 14 and RBI FREE-AI demand oversight + audit.

SUCCESS DEFINITION

≤ 1% unsafe actions auto-executed, 0% injection success, ≥ 65% of safe actions run without a human, every decision explained with a tamper-evident receipt, < 5 ms decision latency.
Measured: **0.5%** unsafe auto-allowed, **0%** injection ASR, **68%** safe auto-completed, p95 2.3 ms (mean of 5 seeds).



© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

Proposed Solution

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

SOLUTION IN ONE SENTENCE

KAVACH uses deterministic policy, provenance tracking, sandboxed consequence analysis and a calibrated risk model to let AI agents act on their own, while blocking or escalating every unsafe action with an auditable receipt.

1 INPUT

The agent's **plan** and **each tool call** (MCP tools/call or JSON):
tool + args, the user's request, role, environment, and earlier tool outputs (for provenance).

2 PROCESS

Hard gates R1–R12 (no AI) → **provenance** of every argument → **sandbox diff** / typed prediction of the effect → **calibrated p(harm)** with interval vs a **reversibility-conditioned τ**.

3 OUTPUT

ALLOW · ALLOW + UNDO · ESCALATE · DENY
4-light scorecard (safe / authorized / explainable / reversible), consequence card for humans, replan hint for the agent, hash-chained receipt.

KEY VALUE / DIFFERENTIATOR

Gate by **measured effect + argument origin**, not by tool type. The LLM never decides. Humans see only the uncertain few.

PROVEN TODAY

- Injected exfiltration and payment: **blocked by provenance (R1)**; injection ASR **0%**.
- Unsafe auto-allowed **0.5%** vs **30%** with rules alone; safe actions automated **68%** vs **12%** when every write needs approval.
- Reversible writes run with a snapshot; **Undo** restores state live.



© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

Architecture & Technical Design

Show the main components, data flow and engineering choices.

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

USER / DEVICE

Any agent (Infosys Foundry, LangGraph, OpenAI-style) with its model on Qualcomm Cloud AI; reviewer on the dashboard; optional UNO Q approval button

APPLICATION / LOGIC

KAVACH gateway (FastAPI, MCP JSON-RPC): manifest pinning, plan check, policy-as-code R1–R12, provenance, HITL queue

AI / DATA LAYER

Sandbox diff (SQLite / files) · 18-feature calibrated risk model · reasoning-blind intent judge + explainer (Llama on Qualcomm)

OUTPUT / ACTION

Verdict + 4-light scorecard · consequence card · undo · replan hint · tamper-evident receipt

TECHNOLOGY CHOICES

Python 3.11, FastAPI, SQLite, NumPy + scikit-learn, YAML policy-as-code, SHA-256 + HMAC, Qualcomm Imagine API (OpenAI-format chat/completions), vanilla-JS UI

ENGINEERING RATIONALE

Cheap and deterministic first, probabilistic last: ~1 ms gates stop most attacks; the LLM only sees ambiguous calls and can only raise scrutiny. MCP makes it drop-in for Foundry.

VALIDATION / RELIABILITY

12 tests; 740 labelled scenarios × 5 seeds; post-execution check auto-rolls back; LLM down → heuristic fallback; unknown tool → fail closed.

DESIGN DECISION

- **Authorization is code, not a model.** A model that reads agent-adjacent text can be prompt-injected; a rule that checks where the recipient came from cannot.
- **Constraint we designed around:** email and payments cannot be sandboxed, so their blast radius is predicted from typed arguments and labelled “predicted”. Decision latency p50 0.8 ms / p95 2.3 ms.



© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

AI Usage & Innovation

Demonstrate meaningful AI use, not AI added only for appearance.

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

AI CAPABILITY USED

Calibrated risk prediction (ML) + LLM intent judging and explanation, inside an agentic-workflow guardrail

INNOVATION / DIFFERENTIATION

Reversibility-conditioned threshold τ = C/(H(1−r)) on a calibrated p with an abstain band; gating by measured effect

AI ROLE

Predicts p(action is unsafe or unintended) with a confidence interval; the LLM scores request ↔ action fit and writes the explanation

INPUT & MODEL

18 typed features (provenance, blast radius, reversibility, intent); bootstrap logistic ensemble + isotonic calibration; Llama on Qualcomm Cloud AI 100

QUALITY CHECK

Held-out ECE 0.13 → 0.03. Uncertain → human. The LLM can only lower trust; an explanation is rejected if it adds a number not in the evidence.

VALUE CREATED

68% of safe actions automated (vs 12% approve-every-write) at 0.5% unsafe auto-allowed; rules alone miss 30%.

WHY NOT RULES ONLY

- “Remove the duplicate for customer 17” becoming “DELETE … WHERE city='Pune' AND tier='gold'” passes every rule. The model sees the measured multi-row blast radius and that the record the user named is not even touched.
- **When it is unsure, it asks:** if the interval straddles τ the action goes to a human. No guessing.



© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

Future Enhancements, Scalability & Security

Present a credible next-step roadmap and the safeguards considered.

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

NEXT ENHANCEMENTS

1. Infosys AgentOS hook (built): DENY blocks, ESCALATE → #approvals queue; next: live tenant run
2. Port AgentDojo + AmPermBench; RAI injection classifier applied to tool outputs
3. UNO Q hardware approval button; NL policy drafting on Qualcomm (human-reviewed)

SCALABILITY

1. Stateless decision service, per-tenant policy + model; horizontal scale
2. Cost-ordered: ~1 ms gates for all; sandbox for writes; LLM only for the ambiguous few
3. Copy-on-write DB branches, WORM receipt store, calibration-drift monitoring

SECURITY & RESPONSIBLE AI

1. Tools reachable only via the gateway; RBAC + four-eyes approvals
2. Secrets never enter agent context; PII masked in receipts; data minimisation
3. Fail-closed; hash-chained receipts; versioned policy; human override always

NOW vs NEXT

- **Works now:** gateway, 12 rules, provenance, SQL/file sandbox, calibrated risk + HITL, receipts, undo, MCP front door, Infosys AgentOS hook adapter, Qualcomm client, benchmark.
- **Next:** live AgentOS tenant run and published-benchmark ports. **Key safeguard:** an LLM can never turn a DENY into an ALLOW.



© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

DEMO

1 Injected email → agent tries to send 200 customers' phones → **DENY [R1]**, recipient traced to msg-4471
2 "Mark inactive customers dormant" → sandbox: 16 rows, reversible → **ALLOW + UNDO** → click Undo
3 "Tidy up the CRM" → DELETE without WHERE: 480 rows → **ESCALATE** with consequence card
4 Injected bank details → ₹95,000 transfer → **DENY**; refund 12,000 → human approval (R5)
5 Tamper with a receipt → chain verification breaks at that record

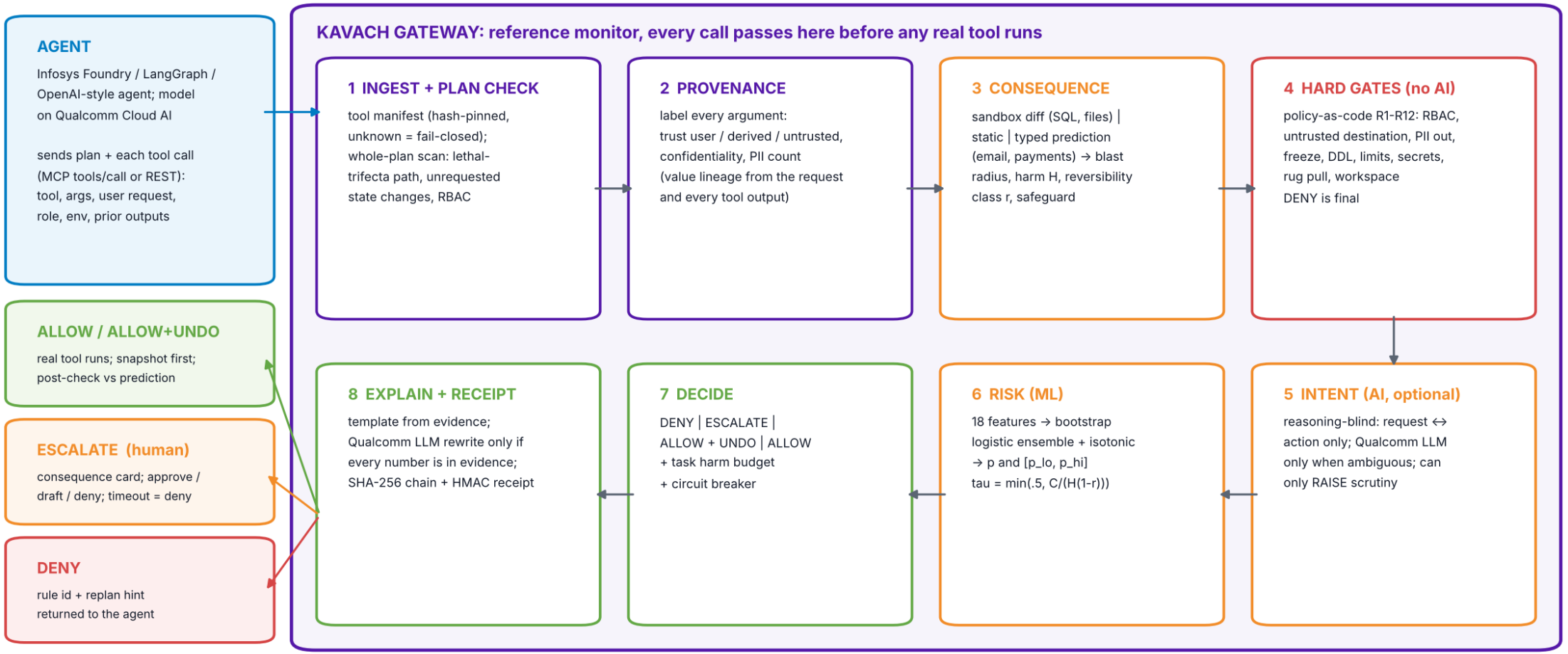


© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

Appendix A · Architecture and data flow

Stages 1–4 and 7 are deterministic; 6 is a small calibrated model; 5 and 8 may call the Qualcomm-hosted LLM.



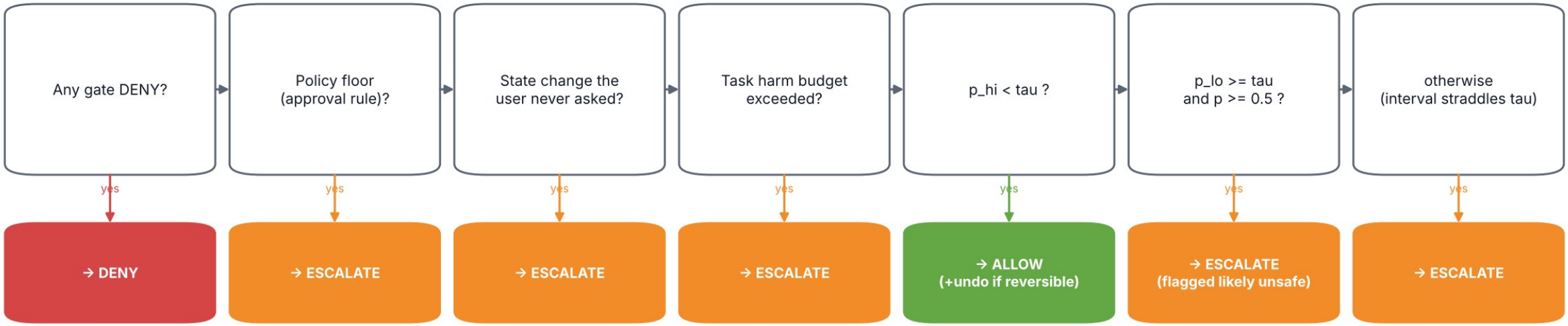


© 2026 Infosys Limited. All rights reserved.

Appendix B · Decision logic, confidence, human-in-the-loop

ENG NEXT 2026
AMPLIFYING ENGINEERING CORE WITH AI-POWERED INNOVATION
ONCE AN ENGINEER, ALWAYS AN ENGINEER.

Decision procedure (first match wins; only deterministic rules can DENY). tau = min(0.5, C_block / (H x (1 - r))) EUH = p x H x (1 - r)



r: idempotent 1.0 · reversible 0.95 (verified snapshot) · compensable 0.5 · irreversible 0. H: measured blast radius in the sandbox, or predicted from typed arguments.

C_block: the organisation's cost of blocking a good action (harm units), chosen on the calibration split.

Confidence. 25 bootstrap logistic models, isotonic-calibrated on a held-out split; [p_lo, p_hi] = 10th–90th percentile. Disagreement widens on unfamiliar actions, which is exactly when the system asks.
Failure handling. LLM timeout → heuristic, never relaxation. Unknown tool → fail closed. Actual effect ≠ predicted → auto-rollback.

Human-in-the-loop. Only escalated actions reach a reviewer, who sees a consequence card (diff, argument sources, reversibility, rule, p). Approve · approve-as-draft · deny. Timeout = deny. Four-eyes for irreversible high-harm actions.
Every human decision becomes a labelled example for recalibration.



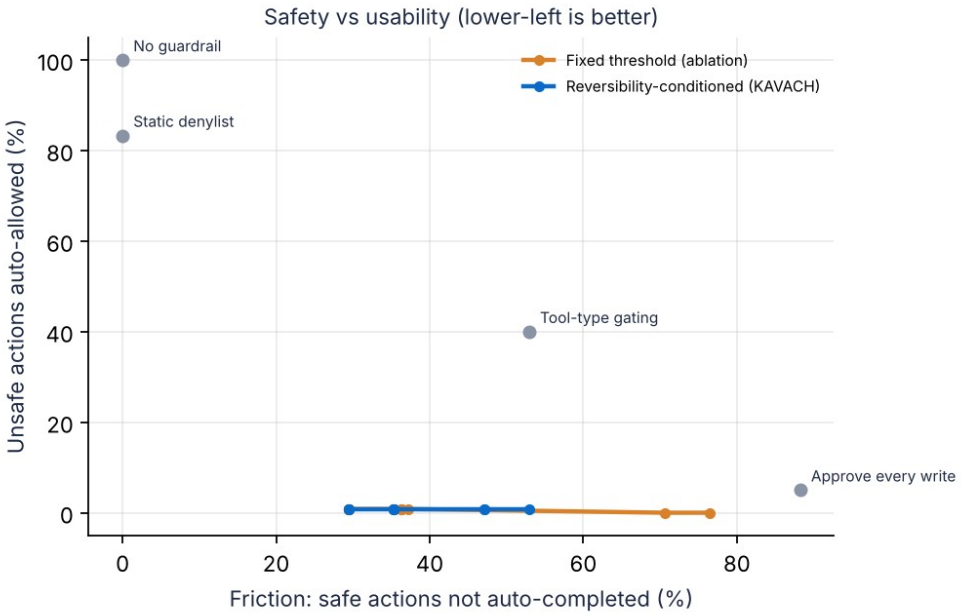
© 2026 Infosys Limited. All rights reserved.

Infosys
Navigate your next

Appendix C · Measured results

740 labelled scenarios, 37 families, 5 seeds, held-out test split. Synthetic (AgentDojo / AmPermBench axes); not comparable with published numbers.

System	Unsafe auto-allowed ↓	Injection ASR ↓	Safe auto-completed ↑	Escalation
No guardrail	100.0% (100%–100%)	100.0%	100.0% (100%–100%)	0.0%
Static denylist (text match)	83.7% (82%–85%)	100.0%	100.0% (100%–100%)	0.0%
Tool-type gating	40.0% (40%–40%)	16.7%	47.1% (47%–47%)	56.8%
Approve every write (manual interrupt)	5.0% (5%–5%)	0.0%	11.8% (12%–12%)	91.9%
KAVACH: rules only	30.0% (30%–30%)	0.0%	94.1% (94%–94%)	8.1%
KAVACH: no provenance	0.5% (0%–2%)	0.0%	48.2% (41%–53%)	60.4%
KAVACH: fixed threshold	0.5% (0%–2%)	0.0%	69.4% (66%–72%)	35.4%
KAVACH (full)	0.5% (0%–2%)	0.0%	68.4% (65%–71%)	35.9%



Read it this way. Rules alone let through ~30% of unsafe actions (overeager scoped deletes, wrong recipients, invented amounts). Approving every write is safe but automates only 12% of safe work.
Honest finding: on this suite the reversibility-conditioned threshold matches a well-tuned fixed threshold; its value is a cost-unit operating point that adapts strictness per action. Calibration ECE 0.13 → 0.03; decision latency p50 0.8 ms.



© 2026 Infosys Limited. All rights reserved.

Appendix D · Today’s guardrails vs KAVACH

How guardrails work today and where they fall short. Verified against papers, docs and repos (Oct 2026).

System	Approach	Published result / limit
Claude Code auto mode	Tool-tier rules + reasoning-blind 2-stage classifier	0.4% FPR, 17% FNR (overeager); AmPermBench: 81% FNR, 36.8% of state changes bypass the classifier
OpenAI Codex CLI	Kernel sandbox, network off, approval policies	Controls where, not what: destructive actions inside the workspace pass
AWS AgentCore Policy	Cedar policies at the tool gateway	Deterministic authorization; no consequence or provenance
NVIDIA NeMo IORails	Tool-call allowlist + JSON Schema	Experimental, structural checks only
Meta LlamaFirewall	PromptGuard 2 + AlignmentCheck	AgentDojo ASR 17.6% → 1.75%, utility 47.7% → 42.7%
Google CaMeL	Control/data-flow separation, capabilities	77% AgentDojo tasks with provable security vs 84% undefended
Progent	Least-privilege policies	AgentDojo ASR 41.2% → 2.2%
Microsoft Fides Gateway	MCP proxy, IFC labels, Rego	Labels + policy; no consequence estimation
Cordon (2026)	Shadow state + effect outbox, validate before commit	Lineage/authority; no magnitude or calibrated strictness
Infosys Foundry + Topaz AgentOS	Tool Interrupt; regex pre-tool gate + hooks → approvals queue; moderation of user text	Run on our suite: defaults pass 95% of unsafe actions; hardened stops them by escalating 86.5% (Appendix F)
KAVACH	Gates + provenance + measured effect + calibrated, reversibility-conditioned risk	Combines the above at one control point; HITL only when uncertain



© 2026 Infosys Limited. All rights reserved.

Appendix E · How we use the Qualcomm platform

Contract read from Qualcomm's python-imagine-sdk 0.5.0 (OpenAI-compatible). Verify the live model list with GET /models on your key.

Role	Model / endpoint	Input → output	If unavailable
Protected agent's brain	Llama-3.3-70B (or listed LLM) · POST chat/completions with tools	user task + tool results → tool calls	demo uses the scripted agent
Reasoning-blind intent judge	Llama-3.1-8B (SDK default, low latency)	request + action + provenance → alignment 0–1	heuristic score; never relaxes
Explanation writer	Llama-3.1-8B	evidence JSON → 3 plain sentences (number-checked)	template explanation
Future: semantic features	BAAI/bge-large-en-v1.5 embeddings, bge-reranker-base	request ↔ action similarity; attack-corpus similarity	feature omitted
Optional edge: Arduino UNO Q	Dragonwing QRB2210 + STM32U585	hardware approval button + LED risk display for irreversible actions	web approval

Auth: Authorization: Bearer $IMAGINE_API_KEY · Base: $IMAGINE_API_ENDPOINT (Cirrascale playground: https://aisuite.cirrascale.com/apis/v2) · every call has a timeout and a deterministic fallback, so a network failure can never turn into an ALLOW.
Why it matters to Qualcomm: Cloud AI 100 is an inference accelerator. KAVACH spends tokens only on ambiguous calls (cost scales with uncertainty, not traffic), and the open Llama models it hosts are the ones that most need an external guardrail.



© 2026 Infosys Limited. All rights reserved.

Appendix F · Infosys's own guardrails, run on our suite

Their code, loaded from the repo (commit 49fe687), on the same 222 held-out test scenarios

System	Unsafe auto-allowed	Injection success	Safe work automated	Sent to a human
PromptGuard (scans user query only)	100.0%	100%	100.0%	0.0%
RAI moderation (perfect-classifier bound)	100.0%	100%	100.0%	0.0%
AgentOS gate, default config	95.0%	100%	100.0%	0.0%
AgentOS gate, hardened (SQL + sends + payments)	5.0%	0%	17.6%	86.5%
Tool Interrupt on every state change	5.0%	0%	11.8%	91.9%
KAVACH	0.8%	0%	70.6%	34.7%

Authorized: PromptGuard and the RAI proxy scan only the user's text; tool outputs (where indirect injections live) are never sent, so even a perfect classifier misses them.
Safe: the AgentOS gate matches command text (regex), not effects; the SQL gate is empty by default. Business thresholds in approval_rules are enforced by the agent's own LLM.
Explainable / reversible: approval cards show tool + 200-char preview; no provenance, blast radius, undo or tamper-evident audit.
Fit: KAVACH runs as an AgentOS PreToolUse hook (integrations/agentos_hook.py). AgentOS keeps routing, sandbox and the approvals queue; KAVACH decides what goes into it.



© 2026 Infosys Limited. All rights reserved.

Appendix G · References

AgentDojo, NeurIPS 2024 D&B (arXiv 2406.13352) · CaMeL, arXiv 2503.18813 · LlamaFirewall, arXiv 2505.03574 · Progent, arXiv 2504.11703
Design Patterns for Securing LLM Agents against Prompt Injections, arXiv 2506.08837 · Cordon, arXiv 2606.17573 · Revisable by Design, arXiv 2604.23283
Measuring the Permission Gate (AmPermBench), arXiv 2604.04978 · Anthropic, Claude Code auto mode (engineering post) · GoEx, arXiv 2404.06921 · ToolEmu, ICLR 2024
KnowNo: Robots That Ask For Help, CoRL 2023 (arXiv 2307.01928) · OWASP Top 10 for Agentic Applications (Dec 2025) · UK AISI × Gray Swan Agent Red-Teaming results (2025)
Gartner press release 25 Jun 2025 · EchoLeak CVE-2025-32711 · Invariant Labs: GitHub MCP exploit (May 2025), MCP tool poisoning (Apr 2025) · Replit incident (Jul 2025)
Simon Willison, The lethal trifecta (Jun 2025) · NVIDIA NeMo Guardrails tool-calling docs · AWS Bedrock AgentCore Policy docs · microsoft/fides-gateway
Infosys Agentic AI Foundry (commit 49fe687: v1.9 + Topaz AgentOS 1.0.0 source) · Infosys Responsible AI Toolkit 2.2.1 · Qualcomm python-imagine-sdk 0.5.0
EU AI Act Art. 14 · RBI FREE-AI framework (Aug 2025) · MeitY India AI Governance Guidelines (Nov 2025)
Code, benchmark and full blueprint: github.com/VismayHS/Kavach_Guardrail



© 2026 Infosys Limited. All rights reserved.